12.Implementing Security Features and Governance / Administration Practices in Zoho Creator

Aim

To configure and study role-based access control (RBAC), authentication security, IP restrictions, audit trails, and governance practices in the Patient Appointment & Scheduling Management application developed using Zoho Creator, with emphasis on protecting patient appointment data.

Overview

Security and governance controls help prevent unauthorized access to patient scheduling records and support accountable administration of the clinic application. The major security features relevant to the project are:

1. **Role-Based Access Control (RBAC):** Assigns access by user role. The existing CEO/Admin, Doctor, and Patient roles have different responsibilities. The **Doctor_Permission** and **Patient_Permission** profiles define allowed forms, reports, and actions.
2. **Security Policies (Password, MFA, and Sessions):** Password requirements and multi-factor authentication (MFA) help secure staff accounts. Session controls reduce exposure from unattended sign-ins.
3. **IP Restrictions:** A conditional access rule can restrict designated clinic staff to approved networks. Such restrictions should not indiscriminately block patients accessing appointments remotely.
4. **Audit Trails:** Records of authorized modifications and administrative actions assist troubleshooting and accountability.

Procedure

Step 1: Setting up Role-Based Access Control (RBAC)

1. Open the Patient Appointment & Scheduling Management application in the Zoho Creator builder.
2. Navigate to **Settings > User Permissions** and review the **Roles** tab.
3. Verify the existing CEO/Admin, Doctor, and Patient roles and their hierarchy.
4. Under **Permissions**, review **Doctor_Permission** and **Patient_Permission**. Allow only authorized form and report access; keep unnecessary Edit, Delete, View all, and Modify all permissions

disabled.

5. Confirm that patients receive access to the restricted **My_Appointments** report rather than unrestricted appointment lists. Test record visibility using separate accounts.

Step 2: Configuring Security Policies (Password and MFA)

1. Open the Zoho Creator administrative dashboard and navigate to **Governance** or **Zoho Directory > Security > Security Policies**, depending on account access.
2. Create a policy for a designated clinic-staff test group. Review the available password length, complexity, and session rules.
3. Under **Conditional Access Policies**, enter a policy name such as **Patient_App_Security_Policy** and select **Allow with MFA**.
4. Limit the policy to a safe test group; select an available authentication method such as Zoho OneAuth or an authenticator app, then review the conditions before activation.
5. Do not enforce organization-wide MFA changes until their effect on users and administrator recovery has been tested.

Step 3: Enforcing IP Restrictions

1. Open the relevant security or conditional access policy and locate its network or Allowed IPs conditions.
2. Enter only verified public IP addresses or approved ranges for an authorized clinic-staff test group.
3. Review the policy scope and retain an emergency administrative access path before saving or enforcing restrictions.
4. Test permitted and denied sign-ins with a separate test account where the feature is available. Avoid applying staff-only restrictions to general patient access.

Step 4: Monitoring Audit Trails and Session Controls

1. In Zoho Creator, open **Operations > Audit Trail** or the equivalent administrative audit section.
2. Select the appointment application and inspect available create, update, and delete events, user identities, and timestamps.
3. Review session lifetime and idle timeout settings under Zoho Directory Security Policies, where supported.
4. Test using fictional appointment records and capture only non-sensitive evidence.

Result

Role-based access settings for the patient appointment application were reviewed using the existing Admin, Doctor, and Patient roles. Zoho Directory security controls, including conditional MFA, password and session policies, IP conditions, and audit trail capabilities, were explored as governance measures. Enforcement of MFA and IP restrictions requires a suitably scoped test group and separate verification; these controls are not represented as fully deployed without that testing.